

NIST CSF Improvement Roadmap

Action ID	Function	Improvement Action	Priority	Timeframe	Owner	Supporting Functions	Success Measure	Evidence / Deliverable	Dependency	Status
IR-001	DETECT	Extend SIEM and monitoring coverage to the legacy ERP system	Critical	0-30 Days	IT Operations	Security Operations; Engineering Lead	100% monitoring coverage for critical ERP assets	SIEM coverage report; monitoring configuration	None	Open
IR-002	DETECT	Define Mean Time to Detect (MTTD) metric and begin monthly tracking	Critical	0-30 Days	Security Operations	GRC Manager	MTTD metric formally defined and reported monthly	MTTD dashboard; monthly security metrics	IR-001	Open
IR-003	RESPOND	Conduct the first incident response tabletop exercise	High	90 Days	IT Operations	GRC Manager; Security Operations; Legal	Tabletop exercise completed and lessons learned documented	Tabletop exercise report; attendance record; lessons-learned register	IR-001	Open
IR-004	PROTECT	Complete the current security awareness training escalation cycle toward the 95% target	High	90 Days	HR	GRC Manager; IT Operations	Awareness completion reaches at least 95%	Training completion report; escalation records	None	Open
IR-005	PROTECT	Automate configuration drift scanning across all cloud environments	High	6 Months	Engineering Lead	IT Operations; Security Operations	Automated configuration drift monitoring operational across all cloud environments	Configuration drift reports; monitoring dashboard	None	Open
IR-006	GOVERN	Tier vendor security questionnaires and reporting by criticality	Medium	6 Months	Legal	GRC Manager; Procurement	All critical vendors assigned risk tiers and reported accordingly	Vendor risk-tiering matrix; supplier risk report	None	Open
IR-007	IDENTIFY	Implement near-continuous asset discovery, including shadow cloud resources	Medium	12 Months	IT Operations	Engineering Lead; Security Operations	Automated asset discovery operating across in-scope environments	Asset discovery reports; updated asset register	None	Open
IR-008	RECOVER	Test the recovery communication plan alongside the next scheduled restoration test	Medium	12 Months	IT Operations	GRC Manager; Business Continuity	Recovery communication plan successfully tested and lessons learned documented	Recovery test report; communication test record; lessons-learned register	Next restoration test	Open
IR-009	GOVERN	Complete full NIST CSF Profile reassessment	Critical	12 Months	GRC Manager	CISO; Control Owners	Current and Target Profiles reassessed and gaps updated	Updated CSF Current Profile; Target Profile; Gap Assessment	IR-001 to IR-008	Open